INFORME PENTESTING

Incidente de Ciberseguridad

4Geeks Academy - Servidor DEBIAN

Analista: Manuel Rosario Marín Fernández

Fecha: 19 de marzo de 2026

INCIDENTE

8 Oct 2024
17:40:59 EDT

Acceso root no autorizado
desde 192.168.0.134

P1 - CRÍTICO

CONTENIDO DE LA PRESENTACIÓN

01 **Resumen del incidente**
Qué ocurrió, cuándo y cómo

02 **Análisis forense - Fase 1**
Vulnerabilidades identificadas y evidencias

03 **Pentesting - Fase 2**
Nuevas vulnerabilidades detectadas

04 **Acciones correctivas**
Remediaciones aplicadas y verificadas

05 **Estado actual de seguridad**
Situación tras las correcciones

06 **Recomendaciones futuras**
Próximos pasos para la gerencia

01 - RESUMEN DEL INCIDENTE

Instalación	INTRUSIÓN	Borrado	Detección	Remediación
Sep 2024	8 Oct 17:40	8 Oct post	Mar 2026	19 Mar
Stack LAMP + WordPress + SSH configurado	Acceso SSH root desde 192.168.0.134	auth.log y syslog eliminados por atacante	Análisis forense identifica el compromiso	Todas las vulnerabilidades corregidas

Control total del servidor - acceso a base de datos WordPress, archivos del sistema y posibilidad de instalar backdoors o exfiltrar datos.

02 - ANÁLISIS FORENSE: VULNERABILIDADES IDENTIFICADAS

V1

SSH root login

CRÍTICA

Login directo como root habilitado. El atacante accedió con contraseña.

V3

FTP anónimo

ALTA

anonymous_enable=YES + write_enable=YES + sin SSL. Subida libre de archivos.

V2

Contraseña BD débil

CRÍTICA

WordPress usaba DB_PASSWORD: 123456. Acceso total a la base de datos.

V4

info.php expuesto

MEDIA

Archivo phpinfo() en directorio público. Expone configuración interna del servidor.

```
Evidencia journalctl - Oct 08 17:40:59 - Accepted password for root from 192.168.0.134 port 45623 ssh2
```

03 - PENTESTING: NUEVAS VULNERABILIDADES

Herramientas:

- Nmap 7.95
- Nikto 2.5.0
- curl

Puertos abiertos detectados:

- 21/tcp — vsftpd 3.0.3
- 22/tcp — OpenSSH 9.2p1
- 80/tcp — Apache 2.4.62

F-01	**xmlrpc.php accesible** CVSS: 8.1 | ALTA	Endpoint WordPress público. Permite fuerza bruta de credenciales y DDoS.	REMEDIADO
F-02	**Directory listing /uploads/** CVSS: 7.5 | ALTA	Listado de archivos habilitado en Apache. Expone todos los archivos subidos.	REMEDIADO
F-03	**Headers HTTP ausentes** CVSS: 6.1 | MEDIA	Sin X-Frame-Options ni X-Content-Type-Options. Clickjacking y MIME sniffing posibles.	REMEDIADO

04 - ACCIONES CORRECTIVAS APLICADAS

🔐 SSH asegurado

PermitRootLogin no
PasswordAuthentication no

Activo

🔑 Contraseña BD robusta

123456 → W0rdPr3ss!Secure#2024
Chmod 640 en wp-config.php

Activo

📁 FTP endurecido

anonymous_enable=NO
ssl_enable=YES

Activo

🚫 xmlrpc bloqueado

.htaccess: Deny from all
Verificado: 403 Forbidden

Activo

🗑️ info.php eliminado

Archivo phpinfo() eliminado
del directorio público

Activo

🔓 Permisos corregidos

wp-config: chmod 640
Propietario: www-data

Activo

05 - ESTADO ACTUAL DE SEGURIDAD

ANTES del incidente		DESPUÉS de las remediaciones
SSH: root login habilitado	→	SSH: acceso root bloqueado
Contraseña BD: 123456	→	Contraseña BD: 20+ chars
FTP anónimo + escritura	→	FTP: auth requerida + SSL
xmlrpc.php: HTTP 200	→	xmlrpc.php: HTTP 403
info.php: phpinfo() público	→	info.php: eliminado
Logs: auth.log eliminado	→	Logs: journal activo

06 - RECOMENDACIONES PARA LA GERENCIA

INMEDIATO

› Instalar Fail2Ban - bloqueo automático de IPs con ataques de fuerza bruta

› Configurar firewall UFW - limitar acceso a puertos 22, 21, 80 por IP

› Activar logging persistente (rsyslog) - evitar pérdida de evidencias

CORTO PLAZO

› Autenticación SSH por clave pública - eliminar contraseñas

› Deshabilitar directory listing en Apache - Options -Indexes

› Añadir headers de seguridad HTTP - X-Frame-Options, CSP

PLANIFICADO

› Auditorías de seguridad trimestrales con Nmap + Nikto

› Sistema de monitorización continua (Wazuh / OSSEC)

› Capacitación del equipo en respuesta a incidentes

CONCLUSIÓN

El servidor ha sido analizado, remediado y verificado.
Todas las vulnerabilidades críticas han sido corregidas.

5
Vulnerabilidades identificadas

5
Remediaciones aplicadas

100%
Vectores de ataque cerrados

El nivel de riesgo ha pasado de CRÍTICO a BAJO.
Se recomienda implementar las medidas adicionales presentadas.

ESTADO FINAL

SSH

FTP

HTTP

MariaDB

xmlrpc